INS6021 · PHÁT TRIỂN PHẦN MỀM · FINAL PROJECT · NHÓM 1

e-HoSo

BÁO CÁO KIỂM THỬ

Test Completion Report · theo ISO/IEC/IEEE 29119-3 · D19, D22, D24, D25, D26

Phiên bản 1.0 · 05/11/2026

Người soạn: Mai Xuân Đạt (QA + DevOps) – do Claude thực hiện theo vai
Người duyệt: Đỗ Văn Tiến (PM)

1. Tóm tắt

Kiểm thử chạy trên commit `591470a` của nhánh `feat/sprint-1`, bằng GitHub Actions và Docker Compose theo chỉ đạo của PM ngày 04/11/2026. Mọi số liệu dưới đây lấy từ log CI và nhánh `evidence` của repo; không có số ước lượng.

Hạng mục	Kết quả
Test backend (JUnit, PostgreSQL 17 thật)	79 test, 0 lỗi
Độ phủ dòng tầng service (ngưỡng 70%)	93,4% (1058/1133 dòng)
Test frontend (Vitest)	5 test, 0 lỗi
Đầu cuối (Playwright trên Docker Compose)	9/9 test Playwright đạt trên x86 và arm64
Yêu cầu có test tham chiếu	47/47 (`tools/req.py rtm`); CI chặn nếu yêu cầu mức M của S1, S2 thiếu test
Lỗi Critical đang mở	0
Chưa kiểm	CK-U02 (3 người dùng thật), CK-P01 trên đúng cấu hình 2 vCPU, 4 GB, CK-P02 giới hạn 20 Mbps, Safari và Edge thật

2. Năm tiêu chí nghiệm thu MVP (D24)

Kết quả do Claude chạy theo vai bằng công cụ tự động. **Chưa có thành viên nào tự chạy lại.**

#	Tiêu chí	Kết quả	Bằng chứng
1	Mỗi thủ tục đi trọn từ Nháp đến Đã trả kết quả	Đạt	`flow.spec.ts`: 3 thủ tục qua API và kho tệp thật; luồng chứng thực qua giao diện; `DossierFlowApiTest`
2	Ngày hẹn trả đúng với mọi ca BR-03	Đạt	`DeadlineCalculatorTest`: CK-H01 → CK-H17
3	Dashboard đúng số đúng hạn, trễ hạn	Đạt	`IntegrityApiTest.dashboardCountsOnTimeAndLateResults`
4	Yêu cầu mức M có ít nhất một ca đạt	Đạt	RTM v1.2: 47/47 yêu cầu có test tham chiếu, CI xanh
5	Không còn lỗi Critical	Đạt	Không có lỗi Critical mở; quét bảo mật ở mục 5

3. Kết quả theo từng ca của Test Plan

Cột "Kết quả" chỉ ghi Đạt khi test có khẳng định đúng nội dung ca. Ca chỉ kiểm được một phần hoặc chưa kiểm được ghi rõ.

Ca	Nội dung	Test	Kết quả
CK-H01 → CK-H17	Ngày hẹn trả: mốc 15:00, 17:00, thứ Sáu, ngày nghỉ, ngày làm bù	`DeadlineCalculatorTest`	Đạt

Ca	Nội dung	Test	Kết quả
CK-B01	Số thứ tự mã hồ sơ theo ngày; giao dịch lỗi không làm nhảy số	`dossierCodeCountsPerDayAndFailedAcceptanceBurnsNoNumber`	Đạt (ca lỗi: sai `version`)
CK-B02	Mã tham chiếu giữ nguyên qua bổ sung	`dossierGoesFromDraftToReturned`, `supplementRoundKeepsReferenceAndCountsRequests`	Đạt
CK-B03	Rút hồ sơ	`withdrawAllowedBeforeAcceptanceOnly`, `DossierLifecycleTest`	Đạt
CK-B04	Gia hạn do xác minh	`verificationExtendsOnceAndOnlyForAllowedProcedure`	Đạt
CK-B05, CK-B06	Nhãn hạn	`DeadlineLabelsTest`	Đạt
CK-B07	Đúng hạn, trễ hạn tại đúng mốc	`resultAtTheDueTimeIsOnTimeAndOneSecondLaterIsLate`	Đạt
CK-B08	Ngày hết giá trị	`marriageResultExpiresAfterSixMonthsOnlyWhenIssued`	Đạt
CK-B09	Đếm số lần bổ sung; thiếu thành phần	`supplementRoundKeepsReferenceAndCountsRequests`	Đạt
CK-V01	Mỗi hành động có đúng 1 dòng nhật ký	`everyActionLogsOnceAndEveryEventIsEmailed`	Đạt
CK-V02	Cặp trạng thái, hành động ngoài bảng trả 409	`everyOtherPairIsConflictWithCurrentStatus`	Đạt
CK-V03	Lỗi ghi nhật ký làm trạng thái quay lại	`statusRollsBackWhenLogFails`	Đạt
CK-V04	Tiếp nhận và rút đồng thời	`acceptanceAndWithdrawalRacingLetExactlyOneWin` (2 luồng, 5 vòng)	Đạt
CK-Q01	Ma trận quyền	`matrixOfRolesIsEnforced`: 16 endpoint × 5 vai trò	**Một phần**: đại diện từng nhóm quy tắc, chưa đủ mọi endpoint
CK-Q02	Hồ sơ người khác, hồ sơ không được giao	`otherOwnersAndUnassignedOfficersAreRefused`	Đạt
CK-Q03	Khoá sau 5 lần sai, mở sau 15 phút	`fiveWrongPasswordsLockForFifteenMinutes`	Đạt
CK-Q04	Sai mật khẩu phê duyệt 3 lần	`wrongPasswordThreeTimesLocksApprovalAndSendBackNeedsReason`	Đạt
CK-Q05	Liên kết hết hạn, dùng lại	`verificationLinkExpiresAfterOneDay`, `passwordResetLinkWorksOnce`	Đạt
CK-Q06	Đổi vai trò, khoá khi đang có JWT	`administratorManagesStaffAndChangesApplyImmediately`	Đạt

Ca	Nội dung	Test	Kết quả
CK-T01, CK-T02	Tra cứu: 4 trường, chặn dò	`publicLookupRevealsNoPersonalData`, `blocksAddressAfterMoreThanTenFailuresForTenMinutes`	Đạt
CK-F01	Loại và dung lượng tệp	`contentDecidesTheTypeAndLimitsApply`, `totalIsLimitedToThirtyMegabytes`	Đạt
CK-F02	URL ký 5 phút, quyền tải	`downloadLinkLastsFiveMinutesAndNeedsPermission`, K4	Đạt
CK-F03	Bù trừ tệp khi CSDL lỗi	`objectIsRemovedWhenTheDatabaseFails`	Đạt
CK-N01	Email theo từng sự kiện, đúng người nhận	`everyActionLogsOnceAndEveryEventIsEmailed`	Đạt
CK-N02	SMTP lỗi	`emailIsRetriedThreeTimesThenFailsWithoutHurtingTheDossier`	Đạt
CK-L01	CSDL từ chối sửa, xoá nhật ký	`databaseRefusesLogChanges`	Đạt
CK-D01	Dashboard, CSV UTF-8	`dashboardCountsOnTimeAndLateResults`	Đạt
CK-E01 → CK-E03	Trọn luồng 3 thủ tục	`flow.spec.ts`, `dossierGoesFromDraftToReturned`	Đạt
CK-C01	`docker compose up` từ bản clone mới	K1	Đạt trên runner GitHub, **chưa chạy trên máy thành viên**
CK-C02, CK-C03	Danh mục; lưu nháp, sửa, mở lại	`catalogShowsThreeProceduresWithComponents`, `draftKeepsItsDataWhenEditedAndReopened`	Đạt
CK-C04, CK-C09	Thiếu dữ liệu khi nộp, khi trình	`submitFailsWhenRequiredFileOrFieldMissing`, `submitForApprovalNeedsOpinionAndDraft`	Đạt
CK-C05	Bổ sung và nộp lại	`supplementRoundKeepsReferenceAndCountsRequests`	Đạt
CK-C06, CK-C07	Danh sách của tôi; hàng đợi	`listsAreScopedAndQueueIsOldestFirst`	Đạt
CK-C08	Phân công, tải việc, công chức bị khoá	`assignmentShowsTheLoadAndRefusesLockedOfficer`	Đạt
CK-C10	Trả kết quả 2 hình thức	`resultIsReturnedEitherWayAndElectronicCopyIsDownloadable`	Đạt
CK-C11	Quản lý tài khoản	`administratorManagesStaffAndChangesApplyImmediately`	**Một phần**: đã kiểm tự khoá; nhánh "quản trị viên cuối" chưa có test riêng
CK-C12	Cấu hình thủ tục, ngày nghỉ	`newDeadlineAppliesOnlyToDossiersAcceptedAfterwards`, `administratorConfiguresProcedureAndCalendar`	Đạt
CK-C13	JaCoCo, Checkstyle, ESLint	CI	Đạt: 93,4% (1058/1133 dòng)

Ca	Nội dung	Test	Kết quả
CK-P01, CK-P02	Hiệu năng	k6, K5	**Một phần**, xem mục 6
CK-S01	OWASP Top 10	Mục 5	**Một phần**: quét thụ động và đối chiếu thiết kế
CK-U01	360 px	`flow.spec.ts`	Đạt
CK-U02	3 người dùng thật	–	**Chưa kiểm**, cần người thật
CK-A01	axe; bàn phím	`compat.spec.ts`	**Một phần**: 0 vi phạm trên 4 màn hình; bàn phím chưa kiểm tay
CK-R01	Khởi động lại dịch vụ	K6	Đạt
CK-X01	4 trình duyệt	`compat.spec.ts`	**Một phần**: chromium, firefox, webkit đạt; chưa kiểm Safari, Edge thật
CK-Z01	Múi giờ	`timesCarryAnOffsetInTheApiAndInTheDatabase`, `acceptedTimeIsReadInVietnamTimeZone`	Đạt

4. Kiểm chứng kho tệp Garage (K1–K7, D17 mục 9)

#	Bước	Kết quả đo được
K1	`docker compose up` từ bản clone mới	Đạt
K2	RAM toàn hệ thống	Rỗi: khoảng 399 MiB; sau luồng kiểm thử: khoảng 447 MiB. Backend giới hạn 1 GiB
K3	Ghi, đọc, xoá qua AWS SDK v2	Đạt, qua luồng API thật
K4	URL ký trong hạn, sửa URL, sau 5 phút	Tải được, đúng nội dung; sửa URL trả 403; sau 310 giây trả 400 "Date is too old"
K5	Tải lên tệp 10 MB	174 ms trên runner, **chưa giới hạn băng thông**
K6	Khởi động lại; xoá dữ liệu	Số hồ sơ trước, sau: 5 và 5; `down -v` đưa lược đồ về 0 bảng
K7	x86 và arm64	Đạt trên `ubuntu-24.04` và `ubuntu-24.04-arm`

Kết luận: giữ Garage, không cần chuyển sang RustFS. Ảnh dùng `dxflrs/garage:v2.5.0`, chạy `--single-node --default-bucket`, nên không cần dịch vụ khởi tạo riêng như SDD v1.0 dự kiến.

5. Bảo mật (D22)

Công cụ: OWASP ZAP baseline (quét thụ động, không tấn công chủ động) trên `https://localhost`; `npm audit --omit=dev`; đối chiếu thiết kế. **Đây chưa phải kiểm thử xâm nhập.** Dependency Java chưa được quét bằng công cụ.

Kết quả quét	Số
ZAP mức High	0
ZAP mức Medium	0
ZAP mức Low	0
`npm audit`	0 lỗ hổng

ZAP còn 4 mục ở mức Informational (Modern Web Application, Storable and Cacheable Content, Re-examine Cache-control Directives, Suspicious Comments), không phải lỗ hổng. Xem `zap/zap.html` trên nhánh `evidence`.

OWASP Top 10 (2021)	**Biện pháp**	**Bằng chứng**
A01 Broken Access Control	Quy tắc vai trò theo URL; kiểm tra chủ hồ sơ, CCTP được giao ở service	`matrixOfRolesIsEnforced`, `otherOwnersAndUnassignedOfficersAreRefused`
A02 Cryptographic Failures	BCrypt; token lưu SHA-256; HTTPS; cookie `HttpOnly`, `Secure`, `SameSite=Strict`	`registerVerifyThenLogin`, `refreshTokenRotates`
A03 Injection	JPA tham số hoá; câu lệnh gốc duy nhất dùng tham số; React tự thoát HTML; email thoát HTML	Đọc mã
A04 Insecure Design	Máy trạng thái phía máy chủ; khoá lạc quan; tra cứu chỉ 4 trường	`DossierLifecycleTest`, `publicLookupRevealsNoPersonalData`
A05 Misconfiguration	Tiêu đề bảo mật, CSP không `unsafe-inline`; không mở cổng backend, kho tệp ra ngoài	ZAP
A06 Vulnerable Components	Phiên bản cố định; `npm audit`	Mục này; **Java chưa quét**
A07 Auth Failures	Khoá sau 5 lần sai; thông báo lỗi chung; token dùng một lần	`fiveWrongPasswordsLockForFifteenMinutes`, `passwordResetLinkWorksOnce`
A08 Integrity Failures	Nhật ký chỉ thêm ở tầng CSDL; CI bắt buộc	`databaseRefusesLogChanges`
A09 Logging Failures	Nhật ký nghiệp vụ, nhật ký quản trị	`dossierGoesFromDraftToReturned`
A10 SSRF	Backend không gọi URL do người dùng nhập	Đọc mã

Rủi ro còn lại: mật khẩu và khoá mặc định trong `docker-compose.yml` chỉ dành cho demo; chứng chỉ HTTPS là chứng chỉ nội bộ, trình duyệt sẽ cảnh báo; giới hạn tra cứu nằm trong bộ nhớ nên mất khi khởi động lại; giới hạn tần suất đăng nhập theo tài khoản, chưa theo IP.

6. Hiệu năng (D25)

Ca	**Điều kiện thực tế**	**Kết quả**	**Ngưỡng NFR-01**
CK-P01	k6, 50 người dùng ảo, 90 giây, GET danh mục thủ tục và danh sách hồ sơ của cán bộ; runner GitHub `ubuntu-24.04`, backend giới hạn 1 GiB; dữ liệu nhỏ (vài hồ sơ)	p95 = 9,08 ms trên toàn bộ yêu cầu; 7491 yêu cầu; lỗi 0%	95% dưới 2 giây
CK-P02	Tải lên 10 MB, không giới hạn mạng	174 ms	Dưới 10 giây ở 20 Mbps

Giới hạn của phép đo: runner GitHub không phải cấu hình 2 vCPU, 4 GB của NFR-01; dữ liệu nhỏ; không có thao tác ghi; k6 chạy cùng máy. Kết quả cho thấy còn dư nhiều, nhưng **chưa khẳng định được** NFR-01 trên đúng cấu hình. Với CK-P02, tính theo lý thuyết truyền 10 MB ở 20 Mbps mất khoảng 4 giây.

7. Phi chức năng khác

Yêu cầu	Kết quả
NFR-02	360 px: đạt trên các màn hình người dân (kiểm tra tràn ngang tự động). 3 người dùng thật: **chưa kiểm**
NFR-06	axe (WCAG 2 A, AA): 0 vi phạm trên 4 màn hình. Điều hướng bàn phím: **chưa kiểm tay**
NFR-07	Phủ test 93,4% (1058/1133 dòng); Checkstyle, ESLint không lỗi; springdoc sinh OpenAPI
NFR-08	Khởi chạy một lệnh; RAM ở K2, dư nhiều so với 8 GB
NFR-09	Kiểm thử khói: chromium, firefox, webkit đạt. Đây là bộ máy trình duyệt của Playwright, chưa phải Safari và Edge thật
NFR-10	`timestamptz`, ISO 8601 có múi giờ; `acceptedTimeIsReadInVietnamTimeZone`

8. Lỗi phát hiện trong quá trình kiểm thử

Lỗi	Mức	Cách phát hiện	Xử lý
Hai `CHECK` trong SQL không chặn `NULL`	Major	Chạy thử lược đồ	Đã sửa
Caddy luôn trả 405 ở cổng 9443 do thứ tự chỉ thị, URL ký không tải được	Major	E2E	Đã sửa
ZAP không kết nối được vì thiếu SNI mặc định	Minor	E2E	Đã sửa
CSP có `unsafe-inline`, thiếu COOP, CORP, COEP	Minor	ZAP	Đã sửa
Tiếp nhận và rút đồng thời có thể gây tranh khoá ở PostgreSQL, API trả 500 thay vì 409	Major	`acceptanceAndWithdrawalRacingLetExactlyOneWin`	Đã sửa

Lỗi	Mức	Cách phát hiện	Xử lý
Hạn JWT so với giờ hệ thống trong khi nơi phát hành dùng đồng hồ của ứng dụng; bộ test sẽ đỏ theo ngày chạy	Major	Rà soát khi viết báo cáo	Đã sửa, thêm `accessTokenExpiresAfterThirtyMinutes`
Test phụ thuộc thứ tự chạy (hàng đợi email)	Minor	CI	Đã sửa